

Warsaw, the 30th
of November
2023

Decision

DKN.5131.26.2023

Based on Article 104 § 1 of the Act of June 14, 1960 – Code of Administrative Procedure (Journal of Laws of 2023, item 775) in connection with Article 7 § 1, Article 60, and Article 102 § 1 point 1 and § 3 of the Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the "Act of May 10, 2018", as well as Article 57 § 1 letters a) and h), Article 58 § 2 letter i), Article 83 § 1 – 3, Article 83 § 4 letter a) in connection with Article 24 § 1, Article 25 § 1, Article 32 § 1 and 2, and Article 83 § 5 letter a) in connection with Article 5 § 1 letter f) and Article 5 § 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 04.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2 and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as the "Regulation 2016/679", after conducting an ex officio administrative procedure regarding the violation of personal data protection regulations by the Warsaw School of Economics located in Warsaw at al. Niepodległości 162, the President of the Personal Data Protection Office, finding a violation by the Warsaw School of Economics located in Warsaw at al. Niepodległości 162 of the provisions of Article 5 § 1 letter f) and § 2, Article 24 § 1, Article 25 § 1, as well as Article 32 § 1 and 2 of the Regulation 2016/679, consisting of the failure to implement:

- 1) appropriate technical and organizational measures ensuring the security of personal data processed in application I., which is a module of the R. information system, and the protection of the rights of data subjects;
- 2) appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of the technical and organizational measures intended to ensure the security of personal data processed in application I., which is a module of the R. information system, particularly in terms of vulnerabilities, errors, and their possible consequences for these systems and the actions taken to minimize the risk of their occurrence, resulting in a violation of the principle of integrity and confidentiality (Article 5 § 1 letter f) of the Regulation 2016/679) and the principle of accountability (Article 5 § 2 of the Regulation 2016/679), imposes on the Warsaw School of Economics located in Warsaw at al. Niepodległości 162, for the violation of the provisions of Article 5 § 1 letter f) and § 2, Article 25 § 1, as well as Article 32 § 1 and 2 of the Regulation 2016/679, an administrative fine in the amount of 35,000 PLN (in words: thirty-five thousand zlotys).

Justification

The Warsaw School of Economics located in Warsaw at al. Niepodległości 162, hereinafter also referred to as "SGH" or "the University", is a public academic institution within the meaning of the Act of July 20, 2018 – Law on Higher Education and Science (Journal of Laws of 2022, item 574), operating under the Statute of the Warsaw School of Economics, the consolidated text of which constitutes an annex to announcement no. [...] of the Rector of the Warsaw School of Economics dated [...] April 2022.

On September 18, 2022, a preliminary notification of a personal data breach, referred to in Article 4 point 12 of the Regulation 2016/679, was submitted to the President of the Personal Data Protection Office, hereinafter also referred to as "the President of UODO" or "the supervisory authority", made in accordance with Article 33 of the Regulation 2016/679 by SGH, as the controller within the meaning of Article 4 point 7 of the Regulation 2016/679, which was registered under the reference number DKN.5130.10053.2022. On September 23, 2022, the University submitted a supplementary notification, detailing the preliminary explanations provided. The personal data breach consisted of the unintentional disclosure on the Internet of information collected in the resources managed by the University in application I., which is a module of the R. information system, resulting in a breach of their confidentiality and – consequently – unauthorized access by third parties to the personal data

processed in this manner concerning (...) students, graduates, and former students (persons removed from the student list) of SGH.

The personal data breach occurred as a result of an error made during programming work aimed at transferring the R. system to a new production server, during which access control to the personal data processed in the system was disabled. SGH explained in the notification that "[a]t the time the programming work began, the L. service was not yet properly configured. In order for the work to proceed, the possibility of unauthorized invocation of subpages of the administrator panel in module I. was allowed on the development server," however, this change "was overlooked and implemented on the production server, and the tests performed did not reveal any malfunction of the system." The incident led to the indexing of unsecured data by the search engine Z., creating the possibility of unlawful processing of such data by third parties.

****Violation of Personal Data Protection Covered the Following Categories of Personal Data:****

First name, last name, parents' names, date of birth, gender, residential or temporary address, PESEL identification number, email address, mother's maiden name, phone number, login, album number, information about the identity card or passport (series and number of the document, country of issue, issuing authority, date of issue, date of validity), citizenship, nationality, possession of the Polish Card, mode, level, and field of study, level of foreign language proficiency, average grades, number of points obtained.

On October 5, 2022, acting under Article 58(1)(a) and (e) of Regulation 2016/679, the President of the Personal Data Protection Office (UODO) issued a request to the University for additional explanations regarding the matter, including, among other things, indicating what the tests of changes introduced to the production server consisted of and who – and based on what procedures – carried them out, whether prior to the occurrence of the personal data breach, as well as after its occurrence, the University conducted a risk analysis for the data processing operations in which the personal data breach occurred, and also how the Z. search engine indexed the data collected in the I. application resources.

In a letter dated November 3, 2022, SGH responded to the questions posed, indicating, among other things, that the aforementioned changes were tested "by the programmer himself," while "another person from the team (...) checked whether the application works correctly," and also declaring that "[a] testing procedure is currently being prepared" and "code review is being introduced, performed by another programmer before new versions of the systems are deployed to production." The University also informed that "[b]efore the occurrence of the breach, the risk analysis was not conducted in a formalized manner," while also submitting attached a "Report [...]" dated [...] November 2022, prepared after the occurrence of the personal data breach. SGH also provided explanations received from the operator of the Z. search engine.

In connection with the above, in order to make additional findings regarding the matter, from November 14 to 18, 2022, based on Article 78(1), Article 79(1), and Article 84(1)(1) of the Act of May 10, 2018, in connection with Article 57(1)(a) and (h) and Article 58(1)(b), (e), and (f) of Regulation 2016/679, an audit was conducted at the University to verify the compliance of personal data processing with the provisions on personal data protection, i.e., with Regulation 2016/679 and the Act of May 10, 2018, which was registered under the reference number DKN.5112.37.2022. The scope of the audit covered the processing of personal data by SGH in connection with the personal data breach reported to the supervisory authority. During the audit, oral explanations were received from University employees, and an inspection of the R. IT system and the I. application was conducted. The findings were detailed in the audit report signed by the Chancellor of SGH, i.e., the person authorized to represent the University.

In connection with the findings made, on August 9, 2023, the President of UODO initiated ex officio administrative proceedings regarding the possibility of a violation by the University, as the data controller, of the provisions of Article 5(1)(f) and (2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679. The proceedings in the matter were registered under the reference number DKN.5131.26.2023. At the same time, in a letter dated August 9, 2023, the President of

UODO requested SGH to submit the results of the “external security audit of the application code” conducted in 2020, which the University mentioned in the notification of the personal data breach, as well as to indicate whether health-related data (disability) collected by SGH at the pre-departure stage in connection with the registration of students for trips organized as part of international student exchange for the purpose of realizing their entitlements were processed through the I. application, and if so – whether this data was covered by the subject personal data breach.

In a letter dated August 31, 2023, the University explained that “(...) this module has never been used by SGH at the pre-departure stage (which is chronologically later than the recruitment stage) for collecting health data. (...) SGH has never processed, nor has it collected in the past and does not currently process personal data regarding disability at the recruitment stage for studying abroad using module I.,” which is why “(...) personal data regarding disability was not covered by the breach that is the subject of these proceedings (...)”. Furthermore, the University provided the President of UODO with “a copy of the report from the external security audit of the application code concerning module I.”

In a letter dated September 28, 2023, the supervisory authority again summoned SGH to provide additional explanations regarding the matter, i.e., to re-present the number of individuals affected by the subject personal data breach and to indicate how and on what basis the University made findings in this regard. In response, within a letter dated October 9, 2023, the University reiterated its position presented in the supplementary notification regarding the number of individuals affected by the subject personal data breach, indicating that this number was determined based on “the analysis of logs recording network and application traffic,” which “was conducted by two independent teams, based on the recruitment numbers whose URLs were opened, indicating potential access to all data contained in a given recruitment.” The University explained that “[a]ccess to the data was directly on the system's page or in the exported file from a given recruitment; if there was no information in the logs about access to the recruitment, the data contained therein was not.”

Read. There was no direct access to the database or its backup copy. The analysis lasted from the moment the event occurred until the submission of the supplementary report, examining the records in the system S. [...] and the local logs of the application I. and network devices. Furthermore, in the content of the aforementioned letter, SGH presented its position regarding the received notification of the initiation of administrative proceedings dated August 9, 2023.

The supervisory authority assessed the evidence in terms of examining its credibility and evidential value. The President of UODO deemed all the evidence submitted by the University to be credible. This is supported by the fact that the individual explanations provided by the University are logical, coherent, and correlate with the entirety of the evidence.

Based on the evidence collected during the explanatory proceedings and the administrative proceedings, as well as during the conducted inspection, the supervisory authority made the following findings regarding the factual state:

1. Nature, scope, context, and purposes of processing.

The University offers its students the opportunity to participate in international student exchange programs, such as CEMS Master's in International Management (CEMS MIM), Erasmus+, The Partnership in International Management (PIM), and others based on bilateral agreements. According to the Regulations [...], which constitute an annex to the Rector's Order No. [...] dated [...] December 2020, the administrative unit of the University responsible for organizing and developing international exchanges for students, doctoral candidates, and SGH employees is the International Cooperation Center.

To support the registration process of SGH students for trips organized under international exchange, the University developed the application I., which is a module of the information system R. This system was developed and implemented by SGH employees. It has been operational since 2014 based on the production server M. The application I. functioned since 2015; however, on September 15, 2022 – due to the identification of a personal data breach – it was permanently disabled.

The database processed within the application I. operated under the control of the database system

P., while access to it was obtained remotely using a computer operating under the control of the operating system X. Access to the resources was authorized. In the login process to both the computer and the database, it was required to enter a username and password.

Candidates entered personal data into the system, including the following categories: first name, last name, parents' names, date of birth, gender, residential or temporary address, email address, maiden name of the mother, phone number, student ID number, information about the identity card or passport (series and number of the document, country of issue, issuing authority, date of issue, expiration date), citizenship, nationality, possession of the Polish Card, mode, level, and field of study, level of foreign language proficiency, average grades, and the number of points obtained. Personal data including login and PESEL registration number were automatically retrieved by the application from the University Study Service System (USOS). The scope of data entered into the application I. was determined based on internal requirements specified in the regulations of SGH and partner universities (e.g., the maiden name of the mother is required by Hungarian universities, while information regarding identity documents is significant for trips taking place both within and outside the Schengen area).

2. Technical and organizational measures previously applied to ensure the necessary security for processing.

By the Rector's Order No. [...] dated [...] May 2018 regarding the protection of personal data at the Warsaw School of Economics, the University introduced the "Policy [...]", aimed at protecting personal data processed at SGH by ensuring their confidentiality, integrity, and availability. The "Policy [...]" defines the principles of personal data protection and covers all individuals involved in the process of personal data processing at the University, as well as contains internal regulations regarding personal data processing, which include:

Annex No. [...]: "Instruction [...]", encompassing general provisions, definitions, procedures for granting permissions for processing personal data and recording these permissions in information systems, methods and means of authentication and their management, procedures for starting, suspending, and terminating work by users of information systems, procedures for creating backups of personal data sets and programs and tools used for their processing, manner, place, and duration of storing electronic information carriers containing personal data and backups, methods for securing the information system against computer virus activity, unauthorized access, and power failure, procedures for conducting reviews and maintenance of systems and information carriers used for processing personal data, and methods for implementing the requirements regarding data processing in the system;

Annex No. [...]: "Obligations [...]";

Annex No. [...]: "Instruction [...]";

Annex No. [...]: "Instruction [...]";

Annex No. [...]: "Principles [...]".

Order of the Rector No. [...] dated [...] September 2020 at the University introduced the "Procedure [...]".

Order of the Rector No. [...] dated [...] May 2021 at the University introduced the "Instruction [...]".

The methodology for assessing the risk of violation of the rights or freedoms of individuals whose data is processed is attached as Appendix No. [...] to the aforementioned document. The University also maintains a register of personal data breaches.

All individuals whose type of work involves access to personal data are required to familiarize themselves with the legal regulations concerning personal data protection and the internal regulations in this regard, particularly with the provisions of the

"Policy [...]" and "Instruction [...]". Furthermore, University employees are obliged to keep the personal data they have access to confidential, as well as the methods of securing it. University employees undergo training in the field of personal data protection. By the Order of the Rector No. [...] dated [...] May 2018, the University launched the mandatory training "GDPR – personal data protection", conducted in the form of directed self-education (e-learning).

The Chancellor of SGH also undertakes additional actions aimed at increasing employee awareness in the area of personal data processing security.

Among the technical and organizational security measures currently employed by the University, it indicated the following: "The security measures described in the Policy [...] introduced by the Order of the Rector No. [...] from 2018 (...). Security measures of the system [...]".

Other security measures in the organization, indirectly related to the system: [...]" 3. The nature and course of the personal data breach.

In connection with the planned shutdown of server M., SGH faced the necessity of transferring the system R. to a new production server (the University indicated that "(...) it was necessary to adapt the application 'R.' to operate on the latest stable version of PHP available at that time (end of April 2022)").

During the preparations for transferring the system – for programming work – "the possibility of unauthorized invocation of subpages of the administrator panel in module I." was allowed on the development server. As a result of an error made by SGH employees, this change was accidentally included in the SVN code repository (i.e., a version control system that allows for managing and tracking changes in files and the source code of the project) and ultimately implemented on the production server. The University indicated that it was "overlooked" and emphasized that "the tests conducted did not reveal any malfunction of the system".

In a letter dated November 3, 2022, SGH explained that the changes made on the development server were tested by "the programmer himself", and after placing them in the repository, "another person from the team (...) checked if the application works correctly". In response to the supervisory authority's inquiry regarding the procedures under which the employee conducted the aforementioned tests, the University did not refer to any applicable methods at that time, only emphasizing that "[p]reparations are underway for a procedure for conducting tests along with the preparation of test scenarios, and code review is being introduced, performed by another programmer before releasing new versions of systems to production".

In the content of the same letter, SGH informed the President of UODO that the risk analysis for the data processing operation in which the personal data breach occurred, taking into account, among other things, vulnerabilities, threats, possible consequences of the breach, and security measures aimed at ensuring the confidentiality, integrity, and availability of processed personal data, was conducted only after the breach occurred, previously "it was not conducted in a formalized manner".

From the information obtained by the University, it follows that in the case of the default activated functionality in the system X. for sending optional diagnostic data to company Y., the browser Q. transmits the URLs visited by the user to the indexing mechanisms used by search engine Z. Due to the fact that access control to the personal data collected by SGH was disabled as a result of the aforementioned error, the URL leading to them became publicly accessible due to the possibility of finding it in the resources of the Internet, made available by search engine Z. After visiting the application I. using browser Q. by one of the SGH employees, the URL leading to the personal data was submitted to search engine Z. and as a result – indexed. The data subject to the personal data breach was indexed solely by search engine Z. and no possibility of accessing it through other search engines, such as search engine A., was identified.

Access to the data disclosed in this way was possible by entering in search engine Z. the first and last name or student album number. The search engine then suggested results in the form of hyperlinks (links) leading to a broader range of data. Based on the displayed suggestions, it was possible to familiarize oneself with data including the first name, last name, and album number. After searching for the student's data and clicking on the hyperlink, it was possible to access data including the first name, middle name, last name, parents' names, date of birth, gender, residential or temporary address, PESEL identification number, email address, maiden name of the mother, phone number, login, album number, information about the identity card or passport (series and number of the document, country of issuance, issuing authority, date of issuance, expiration date), citizenship, nationality, possession of the Polish Card, mode, level, and field of study, language proficiency level, average grades, and the number of points.

As the date of the occurrence of the personal data breach, the University indicated the day of (...) August 2022. The incident was detected by a student of SGH and reported to the Student Government of SGH, and subsequently to the University authorities on (...) September 2022 at 1:00 PM. At 1:30 PM on the same day, SGH confirmed the personal data breach.

Following the receipt of the aforementioned information, the University took action to remedy the breach, as a result of which the system was immediately disconnected from the Internet. The personal data breach thus persisted for a period of 27 days (including the day it ended).

On September 18, 2022, SGH reported the personal data breach to the President of the Personal Data

Protection Office (UODO), which was registered under the reference number DKN.5130.10053.2022. The report was supplemented by the University with additional information on September 23, 2022. The content of the report indicated that the personal data breach involved the unintended publication and unauthorized access to a database containing personal data of (...) individuals, namely students, graduates, and former students (individuals removed from the student list) of SGH.

During the explanatory proceedings, the University conducted an analysis of logins to the R system. This analysis allows for the determination that during the period of the personal data breach, access to the data was obtained by (...) individuals: (...) of them, being students of SGH, found information through the Z. search engine by entering keywords in the form of their first and last names; (...) of them, being the chairperson of the Student Government of SGH, conducted a search to confirm the occurrence of the incident in question. The number of data reads was developed based on the analysis of logs collected by W.

4. Measures taken to remedy the personal data breach, minimize its potential negative effects, and reduce the risk of its recurrence.

As measures taken to remedy the personal data breach and minimize its negative effects for the individuals concerned, the University indicated the following actions:

“Blocking access to the application from the public network”;

“Sending a request to the operator of the Z. browser to remove information from search results”;

“Informing the individuals concerned about the breach, advising caution, and offering a one-year subscription to the BIK Alerts service (...)” – it should be emphasized that SGH also informed that “(...) it enabled the individuals affected by the breach to take advantage of the BIK alerts subscription and covered the costs of document replacement and obtaining a current photograph for the document.

More than (...) students took advantage of the BIK alerts. Additionally, (...) individuals replaced documents at the University’s expense, which amounted to PLN 6726”;

“Ordering students to delete data”;

As security measures taken to minimize the risk of recurrence of the personal data breach, the University indicated the following actions:

“[...]”.

In this factual state, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34(1) and (2) of the Act of May 10, 2018, the President of UODO is the competent authority in matters of personal data protection and the supervisory authority within the meaning of Regulation 2016/679, while pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces its application and conducts proceedings regarding its application, including based on information received from another supervisory authority or another public authority.

Article 5 of Regulation 2016/679 formulates the principles concerning the processing of personal data that must be respected by all controllers, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (“integrity and confidentiality”). According to Article 5(2) of Regulation 2016/679, the controller is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance (“accountability”). The specification of the principle of integrity and confidentiality referred to in Article 5(1)(f) of Regulation 2016/679, as well as the principle...

Accountability, referred to in Article 5(2) of Regulation 2016/679, constitutes further provisions of this legal act.

In accordance with Article 24(1) of Regulation 2016/679, taking into account the nature, scope,

context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, the controller implements appropriate technical and organizational measures to ensure that processing is carried out in accordance with Regulation 2016/679 and to be able to demonstrate this. This means that when assessing the adequacy of the solutions applied, the controller should consider a number of specific factors and circumstances related to the processing, as well as the risks associated with it. Literature indicates (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 24, in: General Data Protection Regulation. Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legalis 2021) that the aforementioned provision “(...) constitutes, among other things, an emanation of one of the fundamental principles of data processing – integrity and confidentiality (...),” and also emphasizes that “(...) the obligations under Article 24 [of Regulation 2016/679] are broader in nature, as the measures applied by the controller must ensure that the entirety (of the data processing process) is compliant with [Regulation 2016/679]. The result of applying the aforementioned measures should be to achieve a state of compliance of the controller's actions with the provisions of [Regulation 2016/679] – indirectly, therefore, although not exclusively, their appropriate security concerning the level of risk (Article 32(1) [of Regulation 2016/679]). The measures applied must indeed be effective, in accordance with Article 24 of Regulation 2016/679.”

At the same time, the controller has the obligation to demonstrate to the supervisory authority that appropriate technical and organizational measures have been implemented so that processing does not exceed the established legal framework, which should be identified with the realization of the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

It should be emphasized that the legislator supplements the content of the norm contained in Article 24(1) of Regulation 2016/679 by adding that these measures should be reviewed and updated as necessary. The implementation of appropriate technical and organizational measures should therefore consist not only of the ad hoc implementation by the controller of the necessary principles, procedures, and practices concerning processing but also of conducting regular reviews of the solutions applied and, where appropriate, improving them. The provision of security for the processed data by the controller is indeed a dynamic, continuous process.

According to Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, as well as the nature, scope, context, and purposes of processing and the risk of infringement of the rights or freedoms of natural persons with varying probabilities of occurrence and severity arising from processing, the controller – both when determining the methods of processing and during the processing itself – implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively realize the principles of data protection, such as data minimization, and to provide the necessary safeguards for processing to meet the requirements of Regulation 2016/679 and protect the rights of data subjects.

As indicated by the European Data Protection Board (EDPB) (Guidelines No. 4/2019 on Article 25, Data Protection by Design and by Default, Version 2.0, p. 4), Article 25(1) of Regulation 2016/679 states that “(...) controllers should consider data protection by design and by default at an early stage, during the planning of the next processing operation. They implement data protection by design and by default prior to processing, as well as continuously during processing, conducting regular reviews of the effectiveness of the selected measures and safeguards. Data protection by design and by default also applies to existing systems that process personal data.” This means that existing systems designed before the entry into force of Regulation 2016/679 should be subject to reviews and maintenance to ensure the implementation of measures and safeguards that effectively implement the principles and rights of data subjects, as specified in these guidelines.

According to Article 32(1) of Regulation 2016/679, the controller, taking into account the state of technical knowledge, the cost of implementation, as well as the nature, scope, context, and purposes of processing and the risk of infringement of the rights or freedoms of natural persons with varying probabilities and severity, is obliged to implement appropriate technical and organizational measures to ensure a level of security appropriate to that risk, including, where appropriate:

- a) pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;
- d) regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure processing security.

Article 32(2) of Regulation 2016/679 indicates that when assessing whether the level of security is appropriate, particular consideration should be given to the risks associated with processing, in particular those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed. the manner in which they are processed.

From the above provisions, it follows that a risk-based approach to personal data protection management is a fundamental concept underlying Regulation 2016/679. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk and take into account the nature of the organization and the mechanisms used for data processing. The consequence of such an orientation is the abandonment of the list of security requirements imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific measures and procedures regarding security, and their determination should occur in a two-step process. First, it is necessary for the administrator to determine the level of risk of infringement of the rights or freedoms of natural persons associated with the processing of their personal data, and then to establish what technical and organizational measures will be appropriate to ensure a level of security corresponding to that risk and to achieve compliance with the provisions of Regulation 2016/679.

According to Recital 75 of the preamble to Regulation 2016/679, the risk of infringement of the rights or freedoms of natural persons, with varying probabilities and severity, may arise from the processing of personal data that could lead to physical harm or material or non-material damage, in particular: if the processing could result in discrimination, identity theft, or identity fraud, financial loss, damage to reputation, breach of confidentiality of personal data protected by professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; if the individuals whose data are processed may be deprived of their rights and freedoms or the ability to exercise control over their personal data; if personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership are processed; and if genetic data, data concerning health, or data concerning sexuality or criminal convictions and related security measures are processed; if personal factors are assessed, in particular analyzed or predicted aspects concerning work performance, economic situation, health, personal preferences or interests, reliability or behavior, location or movement – for the purpose of creating or using personal profiles; or if data of individuals requiring special protection, particularly children, are processed, and if the processing concerns a large amount of personal data and affects a large number of individuals whose data are processed.

The legislator indicates through Recital 76 of the preamble to Regulation 2016/679 that the probability and severity of the risk of infringement of the rights or freedoms of the data subject should be determined by referring to the nature, scope, context, and purposes of the data processing. The risk should be assessed based on an objective evaluation, within which it is determined whether the data processing operations involve risk or high risk.

Recital 83 of the preamble to Regulation 2016/679 indicates that in order to maintain security and prevent processing that is inconsistent with Regulation 2016/679, the administrator should assess the risk specific to the processing and implement measures – such as encryption – to minimize that risk. When assessing the risk regarding data security, the risks associated with the processing of personal data should be taken into account – such as accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data transmitted, stored, or otherwise

processed – which may in particular lead to physical harm, material or non-material damage.

Considering particularly the wide range of personal data processed by SGH through application I., as well as, among others, the number of individuals whose data are processed, in order to properly fulfill the obligations arising from the provisions of Regulation 2016/679, the University was obliged to take actions ensuring an appropriate level of personal data protection by implementing appropriate technical and organizational measures to ensure the security of their processing, as well as to regularly test, measure, and evaluate the effectiveness of the aforementioned measures. Decisions regarding the nature, types, or intensity of such actions should be based on the conclusions resulting from the risk analysis conducted for the processing operations, taking into account, among other things, vulnerabilities, threats, possible consequences of breaches, and security measures aimed at ensuring the confidentiality, integrity, and availability of the processed personal data.

Meanwhile, the gathered evidence indicates that the University managed an information system through which it processed the personal data of its students, former students, and graduates, without conducting a prior analysis of the associated risks. In a letter dated November 3, 2022, SGH explicitly stated that “[p]rior to the occurrence of the breach, the risk analysis was not conducted in a formalized manner.” In the opinion of the supervisory authority, such a manner of operation by the University did not ensure proper control over the aforementioned process in the context of guaranteeing the security of the personal data involved.

the introduced changes, which raises concerns regarding the objectivity and reliability of the testing process.

The lack of a formalized risk analysis related to processing, which should be documented or otherwise recorded and presented in the form of strictly defined, precise formulations explaining and organizing the course of this process, indicates that SGH was unable to demonstrate that, in implementing technical and organizational measures to ensure compliance with Regulation 2016/679, and also assessing whether the level of security of personal data is appropriate, it actually took into account the criteria described in Article 32(1) of Regulation 2016/679, including the risk of infringement of the rights or freedoms of natural persons, as well as the risks associated with processing, particularly those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data, in accordance with the obligation arising from Article 32(2) of Regulation 2016/679.

The findings indicate that the University did not conduct such an analysis throughout the entire period of the system's operation, starting from 2014 (from 2015 in the case of application I.), through May 25, 2018, i.e., the day the application of Regulation 2016/679 began, until [...] November 2022, i.e., the date on which the development of the "Report [...]" is dated, based on the document "Sheet [...]", prepared by the University only after the occurrence of the subject data protection breach.

It should be emphasized that the programming work carried out by the University in August 2022 aimed at transferring the R. system to a new production server was also not preceded by an appropriate analysis of the associated risks. Such conduct is in obvious contradiction to the norms formulated in the content of Regulation 2016/679, which at every stage of implementing the IT system for processing – both in the design, implementation, maintenance, or modification phase – foresee taking into account the risk of infringement of the rights or freedoms of natural persons associated with these operations.

In its guidelines, EROD indicates (Guidelines No. 4/2019 on Article 25, Taking Data Protection into Account at the Design Phase and Default Data Protection, Version 2.0, p. 29) that "the assessment of threats to data security involves analyzing the impact on the rights of individuals and counteracting identified threats," "taking security requirements into account as early as possible in the design and development of the system and continuous integration and execution of appropriate tests," or "regular review and testing of software, hardware, systems, and services, etc., to detect weaknesses in the systems supporting processing" are some of the key elements of taking data protection into account at the design phase and default data protection concerning the principle of data integrity and

confidentiality.

It should be noted that in Section 9A of the data breach notification form, SGH presented a description of the technical security measures previously employed, declaring that as "system security measures," it utilized the security measures described in the "Policy [...]" and other solutions, such as [...]. Furthermore – as additional security measures, albeit only indirectly related to the R. system – the University indicated [...]. However, in the opinion of the President of UODO, these measures cannot be considered adequate in light of the risks associated with the processing of personal data carried out within the framework of application I., particularly concerning the processing that took place during – and as a result of – the transfer of this system to a new production server.

It is also significant that it was during this operation that a University employee made an error, resulting in unauthorized access to personal data collected in the resources of application I. As the findings indicate, SGH did not provide employees with appropriate procedures regulating the aforementioned actions, taking into account, among other things, the principles of handling the personal data stored in the system and the methodology for testing the introduced changes in the context of ensuring the security of processing. As previously indicated, the programmer tested the changes himself, which raises concerns regarding the objectivity and reliability of the testing process.

made the change, while another employee only checked whether the application was functioning correctly. The implementation of appropriate organizational measures in this regard was only declared by SGH in a letter dated November 3, 2022, several months after the occurrence of the personal data breach.

In a letter dated October 9, 2023, the University pointed out that in its opinion, "[i]t is impossible (...) to ensure the security of systems that can never be breached, or, as in this case, it is impossible to protect against all human errors." Following the statement of the Provincial Administrative Court in Warsaw contained in the judgment of January 19, 2021 (case no. II SA/Wa 702/20, Legalis no. 2821108), it should be emphasized that "(...) the data controller should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures their appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing, as well as against unauthorized use of such data and equipment (recital 39 of Regulation 2016/679). (...) The data controller is responsible not only for the actions of its employees but also for the processing of data in the IT system it uses." Therefore, the breach of the provisions of Regulation 2016/679 by SGH did not result from a lack of reliable measures provided by it, but from the failure to implement appropriate measures.

In the aforementioned letter, the University also indicated that "(...) taking into account the state of technical knowledge that the University had at the time when this incident occurred, the solutions adopted and applied by it were at a level corresponding to the risk associated with the operations performed on personal data." In the opinion of the supervisory authority, the implementation by the University of the aforementioned technical measures, without conducting a risk analysis related to the processing being performed at any stage, did not provide an appropriate guarantee that these measures would be adequate, appropriate, and effectively minimize the risk of infringement of the rights or freedoms of the data subjects. The above position of the supervisory authority is also reflected in the judgment of the Provincial Administrative Court in Warsaw of August 26, 2020 (case no. II SA/Wa 2826/19, Legalis no. 2480051), in which the Court stated that Article 32(1) of Regulation 2016/679 "(...) does not require the data controller to implement any technical and organizational measures that are to constitute data protection measures, but requires the implementation of adequate measures. Such adequacy should be assessed in terms of the manner and purpose for which personal data is processed, but the risk associated with the processing of such personal data, which may vary in magnitude, should also be taken into account." At the same time, the Court emphasized that "[t]he adopted measures should be effective; in specific cases, some measures will have to mitigate low risk, while others must mitigate high risk; it is important that all measures (and each one individually) are adequate and proportional to the degree of risk." Furthermore, in the judgment of May 13, 2021, case

no. II SA/Wa 2129/20, the Provincial Administrative Court in Warsaw indicated that “The data controller should (...) conduct a risk analysis and assess what threats it is dealing with.”

Equally importantly, SGH was fully aware of the obligations resting upon it in this regard. This is evidenced, among other things, by the provisions contained in the “Policy [...]”, which states that “[t]he purpose of the Policy [...] (...) is to protect personal data processed at SGH by ensuring that personal data has the properties: 1) confidentiality – a property ensuring access only for authorized persons; (...)”, “personal data is processed in a manner that ensures appropriate security, including protection, using appropriate technical or organizational measures against unlawful or non-compliant processing and accidental loss, destruction, or damage” and that “[t]echnical protection measures include: [...]”.

Additionally, in the “Instruction [...]”, “data security in the IT system” is defined as “the implementation and operation of appropriate technical and organizational measures ensuring the protection of personal data against unauthorized processing within SGH” and it is indicated, among other things, that “[t]he IT system in which personal data is processed is equipped with user authentication mechanisms and access control to resources (authorization).”

At the same time, as indicated in § [...] item [...] of “Obligations [...]”, “[t]he persons managing organizational units are responsible for ensuring compliance with legal regulations and providing appropriate technical and organizational measures regarding the processing of personal data in the respective areas of the University’s operations, in accordance with the University’s organizational structure.” The provision formulated in § [...] item [...] point [...] of the aforementioned document indicates that “[t]he persons referred to in item [...] are responsible for: (...) 7) conducting, at the request of the Administrator, risk analyses of personal data protection and presenting proposals based on them regarding the application of technical measures and organizational initiatives to ensure effective protection of data processing.”

The analysis of the above documents allows us to conclude that the lack of a formal risk assessment conducted by SGH constituted not only a violation of the provisions of Regulation 2016/679 but also of internal regulations aimed at ensuring the proper and secure processing of personal data.

in the organization.

In light of the above, it must be acknowledged that the University has not demonstrated that any of the security measures it implemented protected the data processed through application I. from the risks that ultimately materialized in the form of an incident resulting in a breach of personal data protection. In this context, it is worth recalling the information presented by the University in the document “Sheet [...]” (which – as previously emphasized – was developed only after the occurrence of the personal data breach). The authors of the analysis highlighted several vulnerabilities related to the operation of application I., indicating among them, inter alia, a vulnerability described as “Indexing of resources by search engine bots, error in the application.” This vulnerability, or – as the authors defined it – a potential factor conducive to the occurrence of a threat, was characterized as follows:

“[...]”

As can be seen from the quoted fragment, the aforementioned vulnerability, which had a significant impact on the occurrence of the incident in question, constituted a real threat, against which the University could – and should have – taken adequate actions to neutralize or minimize it. The risk analysis conducted (after the breach of personal data protection) prompted SGH to define the baseline risk associated with the existence of this vulnerability as “critical” (i.e., the highest on the adopted five-point scale, which includes negligible, low, medium, high, and critical risks) and affecting the confidentiality of personal data. However, after the University implemented security measures to reduce the likelihood of the threat occurring, such as, among others, the introduction of mechanisms limiting potential indexing of the resources stored in them by search engines ([...]), this risk was classified as “medium.” It should be noted that these were the actions the University deemed – after conducting the risk analysis – appropriate to ensure a level of security corresponding to this risk; however, they were taken only after the occurrence of the personal data breach, and thus too late to prevent it.

In this context, it is also important to emphasize that access control is a fundamental element of information security, supporting the protection of the organization's assets that are part of the managed IT systems. With appropriate configuration, it helps, among other things, to ensure data confidentiality, guaranteeing that data will be accessible only to authorized individuals, as well as enabling monitoring and recording the actions of individual users. The lack of appropriate access control is often cited as one of the main threats to applications and systems, as evidenced by numerous publications on the subject. In the popular OWASP Top 10 report from 2021, the vulnerability class Broken Access Control was listed as the first of the ten most significant risks to web application security, while the authors of the HackerOne Top 10 list from 2020, which highlights the most frequently reported and most critical security vulnerabilities identified by the global community of security researchers, placed the vulnerability related to uncontrolled access to data, IDOR (Insecure Direct Object Reference), in fifth place.

The findings do not provide sufficient grounds to conclude that the measures employed by SGH to ensure the security of processed personal data were adequate to the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing, as well as the risk of infringement of rights or freedoms of individuals with varying probabilities and severity, which ultimately did not guarantee the effective implementation of data protection principles, including ensuring the confidentiality of personal data processed through application I. At this point, it is also necessary to refer to the conclusions formulated by the University in the "Report [...]" dated [...] November 2022, in which it was stated that "from the risk analysis conducted for application I., which was part of system R., it follows that there are many threats for which the University currently has means to limit the probability of their occurrence – IT, technical, and organizational safeguards. However, it must be emphasized that for some of the identified threats and vulnerabilities, the existing safeguards are not yet sufficient or require additional measures to limit the probability of their materialization."

From the aforementioned report, it follows that a total of 201 threats were identified during the risk analysis, of which 78 were deemed unacceptable and requiring risk management. According to the authors of the report, "(...) the most threats were found in the area of: unauthorized access to the application, violations of data processing principles, unauthorized access to data, data loss." In this context, it is worth noting that – as indicated in the report – following the conducted analysis, the University decided to completely disable application I.

It should be emphasized that the fact that SGH introduced changes in the area of IT system security after the occurrence of the personal data breach does not change the negative assessment of the supervisory authority in this regard, serving only as a basis for refraining from ordering the University to make changes in this area to align data processing operations with the requirements of Regulation 2016/679.

As previously demonstrated, ensuring security of data processing, including the principle of integrity and confidentiality, as specified in Article 5(1)(f) of Regulation 2016/679. The literature indicates (P. Barta, P. Litwiński, M. Kawecki, Commentary on Article 32, in: General Data Protection Regulation. Personal Data Protection Act. Selected Sectoral Provisions. Commentary, ed. P. Litwiński, Legalis 2021) that this principle "(...) imposes on the data controller or processor the obligation to secure data, particularly against unauthorized or unlawful processing and accidental loss, destruction, or damage to data. It should therefore also be understood as preventing access to data by unauthorized persons."

It should be noted that controllers are obliged not only to achieve compliance with the guidelines of Regulation 2016/679 through a one-time implementation of technical and organizational security measures but also to ensure the continuity of monitoring the scale of threats and accountability regarding the level and adequacy of the implemented safeguards. The authors of the aforementioned commentary emphasize that "(...) the obligation to ensure appropriate technical and organizational measures, referred to in Article 32(1) [of Regulation 2016/679], is dynamic (...), as the EU legislator requires regular testing, measuring, and evaluating the effectiveness of the measures applied to

ensure security to a degree commensurate with the risk.”

It is important to emphasize that the aforementioned testing, measuring, and evaluating of technical and organizational measures intended to ensure the security of processing, in order to fulfill the requirement arising from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, which means consciously planning and organizing, as well as documenting such activities within specified time frames, regardless of changes in the organization and the course of data processing processes (in connection with the accountability principle referred to in Article 5(2) of Regulation 2016/679). Thus, the copy of the report from the external security audit of the application code concerning Module I, submitted by SGH in the annex to the letter dated August 31, 2023 (conducted in April 2020), does not, according to the President of UODO, determine compliance with the aforementioned requirements. It only indicates the one-time nature of the actions taken by the University in this regard.

Furthermore, during the explanatory proceedings, in a letter dated October 4, 2022, the supervisory authority requested the University, among other things, to clarify “what the tests of changes made to the production server mentioned in point 4a of the preliminary notification of a personal data breach dated September 18, 2022, consisted of and who performed them,” as well as “on the basis of what procedures of the controller the aforementioned tests were carried out.” In response, in a letter dated November 3, 2022, SGH informed that “[a]fter making changes on the development server, the programmer tested them himself. Then he placed the changes in the repository, which was downloaded by another team member who checked whether the application was working correctly” and added that “[a] procedure for conducting tests is currently being prepared, along with the preparation of test scenarios, and code review is being introduced, performed by another programmer before new versions of the systems are handed over to production.”

From the explanations provided, it follows that the actions aimed at ensuring regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing were only undertaken by the University after the occurrence of a personal data breach. The controller is obliged to verify both the selection and the level of effectiveness of the solutions used at every stage of processing. The complexity of this verification should be assessed in terms of adequacy to risks and proportionality concerning the state of technical knowledge, implementation costs, and the nature, scope, context, and purposes of processing.

In the present factual state, it must therefore be acknowledged that the University did not fulfill the aforementioned obligation. In this regard, it should be noted that the functioning of any organization, especially in the area of personal data protection, cannot be based on unreliable or unrealistic foundations, and neglecting the value of basic information may lead to a false sense of security, resulting in the controller failing to take actions they are obliged to take, which in turn may result, as in this case, in a personal data breach, causing – due to the scope of personal data subject to the breach – a high risk of infringement of the rights or freedoms of natural persons.

The lack of risk analysis resulting in the selection of ineffective security measures and the lack of regular testing, measuring, and evaluating by the University of the effectiveness of the implemented technical and organizational measures intended to ensure the security of processing not only led to the personal data breach referred to in Article 4(12) of Regulation 2016/679 but also determined the breach by SGH of the obligations incumbent upon the data controller, arising from Article 24(1), Article 25(1), Article 32(1), and Article 32(2) of Regulation 2016/679, and consequently also the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679. The effect of the breach of the principle of confidentiality is the infringement of Article 5(2) of Regulation 2016/679. As indicated by the Provincial Administrative Court in Warsaw in its judgment of February 10, 2021 (case no. II SA/Wa 2378/20, *Legalis* no. 2579568), “(...) the data controller is responsible for complying with all principles.” processing of personal data (as mentioned in Article 5(1)) and must be able to demonstrate compliance. The principle of accountability is therefore based on the legal responsibility of the controller for properly fulfilling obligations and imposes on them the duty to provide evidence of compliance with all data processing principles both to the supervisory authority and to the data subject.” Similarly, this issue was interpreted by the Provincial Administrative Court in Warsaw on

August 26, 2020 (case no. II SA/Wa 2826/19, Legalis no. 2480051), stating that “[t]aking into account the entirety of the norms of Regulation 2016/679, it should be emphasized that the controller has considerable discretion regarding the security measures applied; however, they are also responsible for violations of data protection regulations. The principle of accountability directly implies that it is the controller who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679.”

In light of the lack of appropriate measures implemented by SGH to ensure the confidentiality of personal data processed via application I., particularly in the context of the processing operation involving the transfer of system R. to a new production server, it must be stated that prior to the occurrence of the personal data breach, the University did not ensure an adequate level of security for the data processed in this manner. This indicates the failure of SGH to implement appropriate technical and organizational measures to ensure that the processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for the processing, which it was obliged to do under Article 24(1) and Article 25(1) of Regulation 2016/679, as well as the failure to implement technical and organizational measures ensuring a level of security appropriate to the risk of violating the rights or freedoms of natural persons, including, among others, the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services, as required by Article 32(1)(b) of Regulation 2016/679, and also the failure to take into account the risks associated with the processing of personal data referred to in Article 32(2) of Regulation 2016/679, and consequently the violation of the principle of integrity and confidentiality expressed in Article 5(1)(f) of Regulation 2016/679, which results in a breach of the principle of accountability referred to in Article 5(2) of Regulation 2016/679.

According to Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of the measures referred to in Article 58(2) of Regulation 2016/679, an administrative fine under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of the UODO, exercising the authority granted to him under the aforementioned provision, determined that in the case at hand there were grounds justifying the imposition of an administrative fine on the Warsaw School of Economics located in Warsaw at al. Niepodległości 162.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions shaping the obligations of the controller and the processor, referred to in Articles 8, 11, 25-39, as well as 42 and 43, are subject, according to paragraph 2, to an administrative fine of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Pursuant to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject, according to paragraph 2, to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

Furthermore, Article 83(3) of Regulation 2016/679 states that if the controller or processor intentionally or unintentionally violates several provisions of Regulation 2016/679 within the same or related processing operations, the total amount of the administrative fine shall not exceed the amount of the fine for the most serious violation.

In this proceeding, the administrative fine imposed on SGH was for the violation of Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 it was based on Article 83(5)(a) of Regulation 2016/679. At the same time, the fine imposed on the University for the violation of all the above provisions, in accordance with Article 83(3) of Regulation 2016/679, does not exceed the amount of the fine for the most serious violation identified during the proceedings, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which

according to Article 83(5)(a) of Regulation 2016/679 is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total worldwide turnover from the previous financial year.

In deciding to impose an administrative fine, the President of the UODO – in accordance with Article 83(2)(a) – (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present case and which weigh heavily on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the specific

of the Administrative Court in Warsaw, the disclosure of such data can lead to significant risks, including identity theft and other forms of fraud, which can have serious consequences for the individuals affected.

4. Duration of the infringement (art. 83 sec. 2 lit. h) of Regulation 2016/679). The infringement of data protection regulations lasted for an extended period, beginning on May 25, 2018, the date when the provisions of Regulation 2016/679 came into effect, and concluding on (...) September 2022, when the application I. was disconnected from the Internet. It is important to note that the unauthorized disclosure of data, which resulted in the unlawful processing of that data by third parties, occurred on (...) August 2022 (due to the failure of the University to implement appropriate security measures). SGH was obligated to adapt its data processing processes to the requirements of Regulation 2016/679 from the moment it came into effect.

5. The severity of the infringement (art. 83 sec. 2 lit. i) of Regulation 2016/679). The infringement is characterized by its serious nature and significant weight, as it creates a high risk of negative legal consequences for 1461 individuals. The failure of SGH to fulfill its obligation to implement appropriate security measures to protect the processed data from unauthorized disclosure not only poses a potential risk but also a real possibility of misuse by third parties in violation of the provisions of Regulation 2016/679, without the knowledge and against the will of the individuals whose data is concerned.

6. Conclusion. In light of the findings in this case, it must be concluded that SGH, despite its awareness, committed a gross negligence resulting in a breach of the confidentiality of the processed data, which is a significant circumstance affecting the level of the administrative monetary penalty. The unauthorized access to the personal data of students, graduates, and former students of SGH stored in the resources of application I. was made possible due to the University's failure to exercise due diligence, which, in the assessment of the supervisory authority, indicates the intentional nature of the infringement.

7. Final remarks. The University should have been aware that the adopted solutions would not ensure an adequate level of security for personal data, which could lead to a breach of data protection regulations. The analysis of the internal regulations adopted by the University confirms its awareness of the potential threats arising from the processing of personal data through IT systems.

In summary, the infringement of data protection regulations by SGH is characterized by its serious nature, the high number of affected individuals, and the prolonged duration of the infringement, all of which contribute to the imposition of an administrative monetary penalty.

the strong administrator of data (art. 83 ust. 2 lit. e) of Regulation 2016/679). In the opinion of the President of UODO, SGH did not have earlier violations, which could influence the amount of the fine.

3. Category of personal data, to which the violation (art. 83 ust. 2 lit. g) of Regulation 2016/679). The violation concerned personal data of a specific character, in particular the PESEL number, which increases the weight of the violation.

4. Volume of processed personal data (art. 83 ust. 2 lit. h) of Regulation 2016/679). The violation concerned the data of many people, which also influences its weight.

5. All other circumstances concerning the violation, in particular the way in which the violation was committed

ujawnione (art. 83 ust. 2 lit. i) rozporządzenia 2016/679). Naruszenie zostało ujawnione w wyniku działań administratora, co należy uznać za okoliczność łagodzącą.

W związku z powyższym, Prezes UODO uznał, że nałożona kara administracyjna w wysokości PLN 50,000 jest adekwatna do stwierdzonego naruszenia oraz okoliczności sprawy. Kara ta ma na celu nie tylko ukaranie administratora, ale również zniechęcenie do podobnych naruszeń w przyszłości oraz ochronę osób, których dane dotyczą.

Decyzja ta jest ostateczna i przysługuje od niej odwołanie do sądu administracyjnego.

****Administrator's Side (Article 83(2)(e) of Regulation 2016/679)****

The President of the UODO did not find any previous violations of data protection regulations on the part of SGH, which means there are no grounds to consider this circumstance as aggravating. It is the duty of every administrator to comply with legal regulations, and therefore the absence of previous violations cannot be considered a mitigating circumstance when imposing sanctions.

****3. The manner in which the supervisory authority became aware of the violation, in particular, whether and to what extent the administrator reported the violation (Article 83(2)(h) of Regulation 2016/679).****

The President of the UODO established that SGH violated data protection regulations as a result of a data breach notification made by the University. By making the notification, SGH was fulfilling its legal obligation; therefore, there are no grounds to consider this fact as a mitigating circumstance. The Article 29 Working Party indicates in Guidelines WP 253 that “[t]he supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notifications from the data controller. According to the regulation, the controller is obliged to notify the supervisory authority of a data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor.”

****4. If measures have previously been applied to the administrator in the same case, as referred to in Article 58(2) – compliance with those measures (Article 83(2)(i) of Regulation 2016/679).****

Prior to issuing this decision, the President of the UODO did not apply any of the measures mentioned in Article 58(2) of Regulation 2016/679 to SGH in the case under consideration, which means that the University had no obligation to take any actions related to their implementation, actions that, if assessed by the supervisory authority, could have a burdensome or mitigating effect on the evaluation of the established violation.

****5. The application of approved codes of conduct under Article 40 or approved certification mechanisms under Article 42 (Article 83(2)(j) of Regulation 2016/679).****

SGH does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not – as stipulated by the provisions of Regulation 2016/679 – mandatory for controllers, which means that the circumstance of their non-application cannot be considered against the University in this case. On the contrary, the circumstance of adopting and applying such instruments could be taken into account in favor of the University as measures guaranteeing a higher than standard level of protection for the processing of personal data.

****6. Any other aggravating or mitigating factors applicable to the circumstances of the case, such as financial benefits obtained directly or indirectly in connection with the violation or avoidance of loss (Article 83(2)(k) of Regulation 2016/679).****

The President of the UODO did not find that SGH obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to consider this circumstance as aggravating for the University. The establishment of measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. The fact that SGH did not achieve such benefits, as a natural state independent of the violation and its consequences, is a circumstance that inherently cannot be mitigating for the University. This interpretation is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits “obtained” – that have occurred

on the part of the entity committing the violation.

The President of the UODO, having comprehensively considered the matter, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty. Taking into account all the circumstances discussed above, the President of the UODO concluded that imposing an administrative monetary penalty on SGH is necessary and justified by the weight, nature, and scope of the violations attributed to the University. It should be noted that applying any other corrective measure provided for in Article 58(2) of Regulation 2016/679 to SGH, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportional to the identified irregularities in the processing of personal data and would not guarantee that the University would not commit further negligence in the future.

Regarding the amount of the administrative monetary penalty imposed on SGH, it should be noted that in the established circumstances of this case, given the identification of violations of several provisions of Regulation 2016/679, namely the principle of integrity and confidentiality of data, expressed in Article 5(1)(f) of Regulation 2016/679, and reflected in the form of obligations specified in Article 25(1), Article 32(1), and Article 32(2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679, which is an emanation of the principle of accountability, as well as the fact that the University is an entity of the public finance sector, Article 102 of the Act of May 10, 2018, applies, which limits the amount of the administrative monetary penalty that can be imposed on an entity of the public finance sector to the amount of 100,000 PLN (in words: one hundred thousand zlotys). In the opinion of the supervisory authority, the applied administrative monetary penalty fulfills, in the established circumstances of this case, the functions of which...

referring to Article 83(1) of Regulation 2016/679, i.e. it will be effective in this individual case, proportional, and deterrent.

According to the President of the Personal Data Protection Office (UODO), the penalty imposed on SGH will be effective, as it will lead to a situation in which the University will implement technical and organizational measures that ensure a level of security for the processed data corresponding to the risk of infringement of the rights and freedoms of the individuals to whom the data pertains, as well as the severity of the threats associated with the processing of such personal data. The effectiveness of the penalty is therefore equivalent to a guarantee that SGH, from the moment of the conclusion of these proceedings, will approach the requirements set by the data protection regulations with the utmost diligence.

The administrative monetary penalty applied is also proportional to the established infringement, particularly in terms of its severity, impact, the scope of affected individuals, and the high risk of negative consequences that they may suffer in connection with the infringement. In the opinion of the President of UODO, the administrative monetary penalty imposed on the University will not constitute an excessive burden for it. The amount of the penalty has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of infringement of obligations by SGH, while not causing, on the other hand, a situation in which the necessity to pay it would lead to negative consequences in the form of a significant deterioration of the University's financial situation.

In the opinion of the President of UODO, SGH should – and is able to – bear the consequences of its negligence in the area of data protection, which is why he considers the imposition of a penalty in the amount of 35,000 PLN (in words: thirty-five thousand zlotys) to be fully justified.

In the opinion of the supervisory authority, the administrative monetary penalty will also serve a repressive function in these specific circumstances, as it will respond to SGH's infringement of the provisions of Regulation 2016/679, but it will also have a preventive function, contributing to the prevention of future infringements of the University's obligations arising from data protection regulations.

According to the President of UODO, the administrative monetary penalty applied meets the criteria

referred to in Article 83 of Regulation 2016/679, given the severity of the established infringements in the context of the fundamental requirements and principles of Regulation 2016/679, particularly the principle of integrity and confidentiality expressed in Article 5(1)(f) of Regulation 2016/679.

The purpose of the imposed penalty is to ensure compliance by SGH with the provisions of Regulation 2016/679 in the future.

In this factual and legal situation, the President of the Personal Data Protection Office has decided as stated in the operative part.

Print article

Metadata

Entity providing the information:

Department of Control and Infringements

Created by:

Jan Nowak

2023-11-30

Entered by:

Wioletta Golańska

2024-02-21 10:34:18

Last modified by:

Edyta Madziar

2024-05-24 11:08:26